API Security Risk Analysis Report

Target API: https://jsonplaceholder.typicode.com

Prepared By Given Dumisa

Date: April 2026

Organization: Future Interns Cyber Security Task 3

Executive Summary

This report presents a read-only API security risk analysis conducted on the public API https://jsonplaceholder.typicode.com. The objective of this assessment was to identify potential security risks in API design, data exposure, and access control without performing any intrusive or harmful actions. The analysis revealed several common API security weaknesses, including a lack of authentication, excessive data exposure, and the absence of rate-limiting controls. Although the API is designed for testing purposes, these findings reflect real-world risks that can impact production systems if not properly addressed. This report provides clear recommendations to improve API security and reduce potential abuse.

Objectives

- Analyse API endpoints and responses
- Identify common API security risks
- Evaluate authentication and access control
- Classify risks based on severity
- Provide actionable remediation recommendations

Scope & Methodology

Scope:
This assessment was limited to publicly available endpoints of the API. Only read-only requests were performed.

Methodology:
- API testing using Postman
- Inspection of request/response data
- Analysis of headers and endpoints
- Review of API documentation

No exploitation or harmful actions were performed during this assessment.

API Overview

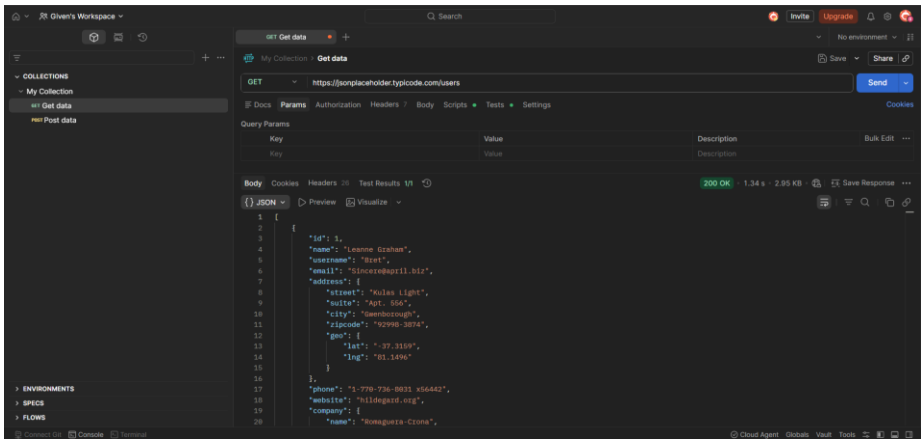
The tested API provides placeholder data for users, posts, comments, and other resources.
Example endpoints:
- /users
- /posts
- /comments

The API is publicly accessible and does not require authentication.

Findings Summary

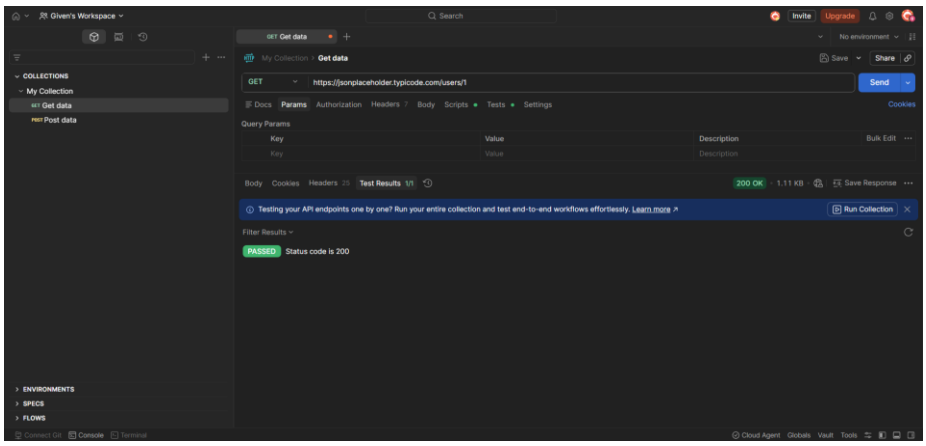
	Risk	Severity
1	No Authentication Required	High
2	Excessive Data Exposure	Medium
3	No Rate Limiting	Medium
4	Predictable Resource Access	Medium
5	Lack of Input Validation Indicators	Low

Testing the first endpoint



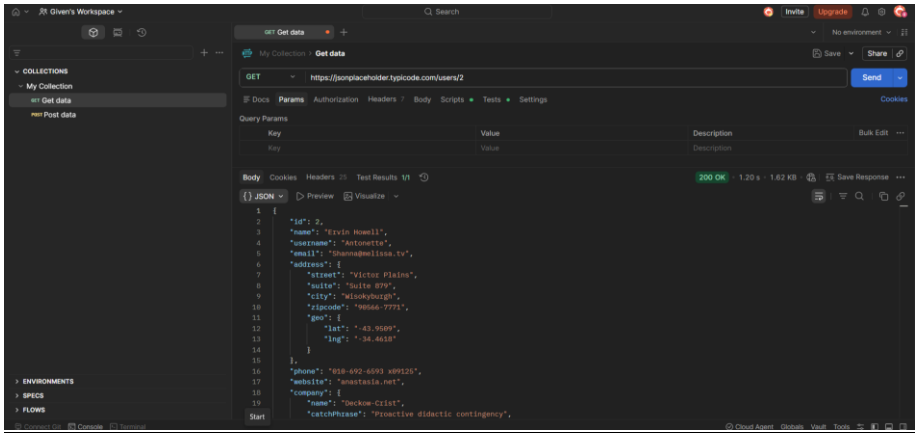
- The API allows access to user data without authentication, indicating a lack of access control.

Testing individual user access



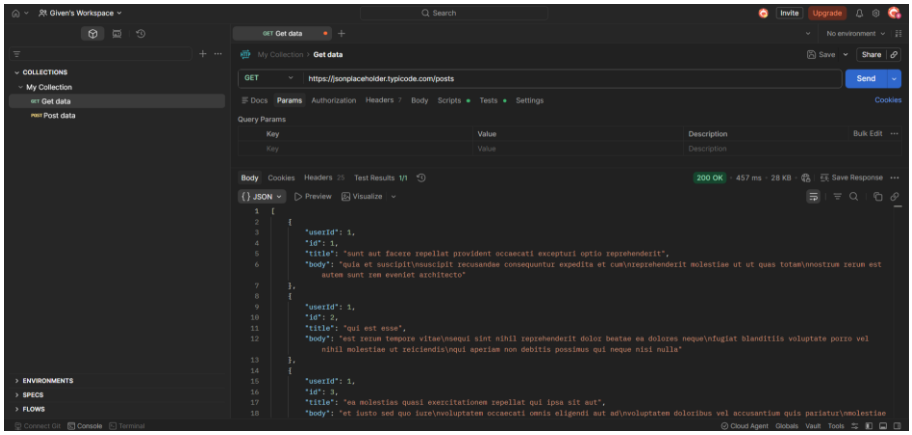
- The API allows predictable access to resources using sequential IDs, which may lead to data enumeration.

Testing another user



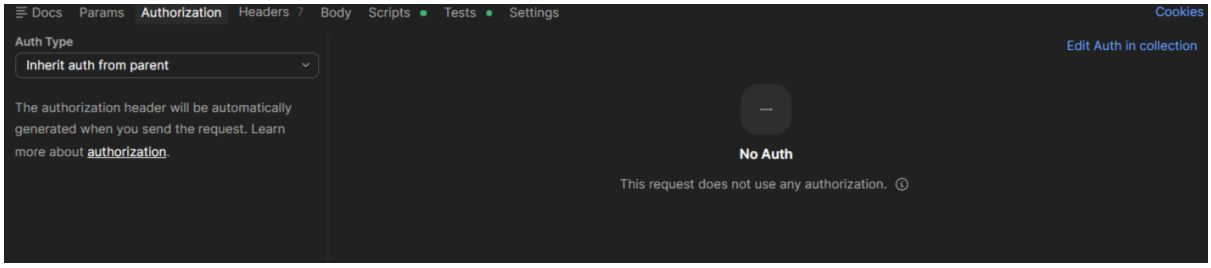
- Attackers can iterate through user IDs to collect large amounts of data.

Testing posts endpoint



- The API returns excessive data without filtering, increasing exposure risk.

Authentication Status



- The API does not require authentication, allowing unrestricted access to all endpoints.

Rapid Requests - The API does not enforce rate limiting, allowing unlimited requests.

Details Risk Analysis

1. No Authentication Required

Description:
The API allows access to all endpoints without requiring authentication.

Risk Level:
High

Impact:
Any user can access sensitive data without verification, increasing the risk of data scraping and misuse.

Recommendation:
Implement authentication mechanisms such as API keys, OAuth tokens, or JWT-based authentication.

2. Excessive Data Exposure

Description:
API responses return full datasets, including user details, without filtering.

Risk Level:
Medium

Impact:
Unnecessary exposure of data increases the risk of data misuse and privacy concerns.

Recommendation:
Return only necessary fields and implement data filtering on responses.

3. No Rate Limiting

Description:
The API does not appear to enforce request limits.

Risk Level:
Medium

Impact:
Attackers can send unlimited requests, potentially leading to abuse or service disruption.

Recommendation:
Implement rate limiting to restrict the number of requests per user or IP.

4. Predictable Resource Access

Description:
Resources can be accessed using predictable IDs (e.g., /users/1, /users/2).

Risk Level:
Medium

Impact:
Attackers can enumerate and collect large amounts of data.

Recommendation:
Implement access control checks and consider using non-sequential identifiers.

5. Lack of Input Validation Indicators

Description:
The API does not clearly demonstrate strong input validation mechanisms.

Risk Level:
Low

Impact:
Poor validation may lead to injection or data integrity issues in real systems.

Recommendation:
Validate and sanitize all inputs on the server side.

Recommendations

- Implement strong authentication (API keys, OAuth, JWT)
- Limit data exposure to only required fields
- Enforce rate limiting to prevent abuse
- Apply proper authorization checks
- Validate all user inputs
- Monitor API usage and logs regularly

Conclusion

The API security assessment identified several common risks associated with modern API design, particularly around authentication, data exposure, and access control. Although the tested API is intended for demonstration purposes, these findings reflect real-world vulnerabilities that can impact production systems. By implementing the recommended security controls, organizations can significantly reduce the risk of unauthorized access, data leakage, and abuse of API services.